

4.1.2 Practice – Pretexting and Impersonation

Question 1

You are creating a social engineering campaign that targets a penetration testing client for Protego. You are working on a business email compromise (BEC) in which you create a false identity that appears to be an employee of a partner company. You have spoofed the source email address and copied graphical aspects of the emails that you will send to make them look like they come from the legitimate company. Once you have established communication with the client, you will request sensitive information about the client's financial accounts. What type of attack are you creating?

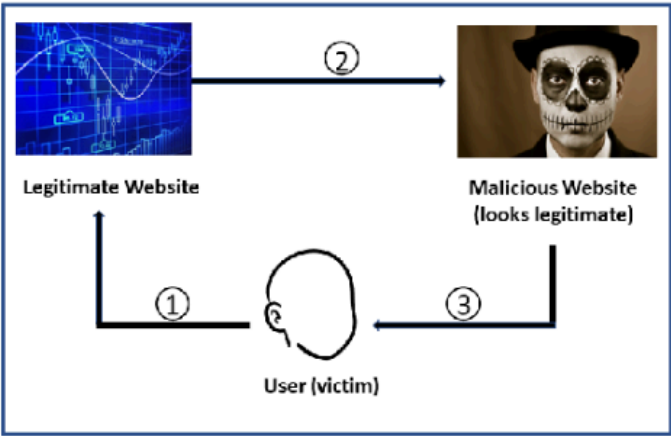
- ☒ pretexting
- ☐ social engineer interrogation
- ☐ whaling
- ☐ pharming

Question 2

You have been asked to set up an attack as part of a penetration testing engagement for Protego. It involves an attack in which you follow this process (as shown in the figure). In step 1, an employee of the client enters the URL of a frequently used website. In step 2, because you have previously compromised the employee's system and altered the hosts file with a false mapping of IP address to URL, the employee is redirected to a malicious site that you cloned from the legitimate website. In step 3, malware is downloaded and installed on the employee's system.

What type of attack have you been asked to create?

- ☐ piggybacking
- ☐ vishing
- ☐ phishing
- ☒ pharming



4.2.7 Practice - Pivot Attack

During initial interviews and surveys of Pixel Paradise's employees, we discovered that they had already experienced all of the following social engineering attacks. Which one is a pivot attack?

Employees reported receiving emails, supposedly from the Chief Technology Officer, William A. Hurst, that look legitimate.

One of Pixel Paradise's fan community websites was compromised by an attacker who injected JavaScript code to redirect community members to a site containing malicious exploit code.

A receptionist received a call from an attacker attempting to persuade them to reveal information about Elizabeth deGray, the CEO.

Pixel Paradise's employees have been receiving emails from a supposedly trusted source with links and attachments.

4.2.8 Practice - Social Engineering Attacks

Following our initial interviews with employees and other stakeholders at Pixel Paradise, it is important that we properly classify the types of social engineering attacks that they have experienced. This helps us to create targeted mitigation recommendations that suit the specific client. To practice this skill, match the description of the social engineering attack to the type of attack.

Categories:

Whaling

Spear phishing

Watering hole

Vishing

Options:

An administrative assistant at Protego reported receiving an email that contained a link to a site that resembled a valid, trusted resource. When they clicked the link, they were prompted to supply a username and password to login.

Several Protego employees received text messages that instructed them to click on a link to confirm an account and claim a bitcoin reward. The site required registration with personal and work-related information.

Protego received an alert from a legitimate game developers' news website that the site had been experiencing unusual traffic including what appeared to be automated vulnerability scans.

An employee reported receiving a phone call from someone who claimed to represent a vendor. The caller claimed that Protego was due a refund and a business account number was required to transfer the money.

A

B

C

D

E

F

C

D

Email phishing

SMS phishing

USB drop key

E

F

G

✓

An employee who was visiting an electronic gaming tradeshow found a USB drive that they inserted into their laptop. Malware infected the computer requiring it to be replaced.

✓

The Vice President of Finance and Director of Accounting at Protego both received emails that contained links to an online survey regarding financial management. One of them clicked into the link and their anti-malware app blocked a malicious file download.

✓

The Protego Chief Technology Officer reported that the company spam filter blocked several emails that used Protego logos and came from a spoofed Protego email account.

4.3.6 Practice – Physical Attacks

Match the type of physical attack to the description.

Categories:

A person obtains information such as personally identifiable information (PII), passwords, and other confidential data by looking over the victim's shoulder.

An unauthorized person tags along with an authorized person to gain entry to a restricted area **without** the consent of the authorized person.

A person scavenges for private information in garbage and recycling containers.

An unauthorized person tags along with an authorized person to gain entry to a restricted area **with** the consent of the authorized person.

A person clones a card used to access a building.

Options:

✓ shoulder surfing

✓ piggybacking

✓ tailgating

✓ dumpster diving

✓ badge cloning

4.4.4 Practice – Browser Exploitation Framework

In the Pixel Paradise penetration test, Protego will use BeEF as part of an exploitation campaign. How could BeEF be used?

to spoof a legitimate caller ID

to create and send spear phishing emails

✓

to send fake notification messages to compromised browsers

to create USB drives that are infected with malware to be distributed in the parking lot

4.4.6 Practice - Call Spoofing Tools

The scope of the Pixel Paradise pentest includes social engineering tests. Protego will attempt several vishing attacks to test the security awareness of Pixel Paradise employees. You have been asked to evaluate call spoofing tools to be used in the vishing attacks. Match the call spoofing tools to the descriptions.

Categories:

Asterisk

SpoofCard

SpoofApp

Options:

A

A

✓

a legitimate VOIP management tool that can also be used to impersonate caller ID

B

C

✓

an Apple iOS and Android app that can be used to spoof a phone number easily

C

B

✓

an Apple iOS and Android app that can spoof a number and change your voice, record calls, generate different background noises and send calls straight to voicemail

Skills Check

How can you use the exploit that you created in the lab in an actual penetration test?

A malicious webpage can be placed on a web server that employees commonly use.

Employee traffic intended for a corporate web site can be intercepted and redirected to a malicious site.

✓

A link to a malicious clone of an organization’s website can be distributed in a phishing email that is sent to employees.

Malicious code can be inserted into the corporation’s website.

Skills Check

In the lab, how did we use BeEF to exploit a user’s browser? (Choose two.)

We used the browser to create a denial-of-service attack against a web server

✓

We were able to view user actions in the browser, such as entries they made in text fields.

✓

We created a fake browser notification that, when clicked, sent the user to a website of our choosing.

We used BeEF to download malicious files into the browser that caused the browser to crash.

4.5.2 Practice - Methods of Influence

You have been asked to participate in a social engineering campaign in the Pixel Paradise test. You are required to compose email messages and call scripts to be used in the campaign. This involves developing strategies to influence employees to visit a website that is infected with BeEF hook.js scripts. Match each of the methods of influence to how you would use it.

Categories:

likeness

authority

scarcity

social proof

fear

Options:

A

B

C

D

E

✓

You act with confidence and invoke legal, organizational, or social power to convince victims to comply.

✓

You impersonate someone who a victim is likely to admire, or you put a victim in a situation in which they feel that others will feel positively about them if they comply.

✓

You force victims to act quickly to avoid or rectify a dangerous or unpleasant situation.

✓

You create a feeling of urgency in a decision-making context.

✓

You manipulate employees that you put in an unfamiliar situation by mentioning what other people do in that situation.

Question 1

What type of threat allows an attacker to obtain the credentials of a bank client by spoofing the login webpage of a financial institution?

piggybacking

vishing

whaling

✓

malvertising

Question 2

What is a watering hole attack?

an attack carried out in a phone conversation

an attack targeted at high-profile business executives and key individuals in a company



an attack that exploits a website that is commonly accessed by members of a targeted organization

an attack performed by an unauthorized person who tags along with an authorized person to gain entry to a restricted area

Question 3

What is the act of gaining knowledge or information from a victim without directly asking for that particular information?

influence



elicitation

interrogation

impersonation

Question 4

A threat actor has altered the host file for a commonly accessed website on the computer of a victim. Now when the user clicks on the website link, they are redirected to a malicious website. What type of attack has the threat actor accomplished?

phishing

vishing



pharming

tailgating

Question 5

Why would a threat actor use the Social-Engineering Toolkit (SET)?

- ☒ to send a spear phishing email
- ☐ to spoof a phone number
- ☐ to manipulate users by leveraging XSS vulnerabilities
- ☐ to practice social engineering elicitation, interrogation, and pretexting skills

Question 6

Which option is a voice over IP management tool that can be used to impersonate caller ID?

- ☐ SpoofCard
- ☒ Asterisk
- ☐ SpoofApp
- ☐ Nikto

Question 7

A salesperson is attempting to convince a customer to buy a product because limited supplies are available. Which social engineering method of influence is being used by the salesperson?

- ☐ social proof
- ☐ authority
- ☐ likeness
- ☒ scarcity

Question 8

What method of influence is characterized when a celebrity endorses a product on social media?

- ☒ social proof
- ☐ scarcity
- ☐ authority
- ☐ fear

Question 9

Apple is a company constantly working towards making its products and processes more environmentally friendly. Therefore, the Apple brand is associated with ideals and values that customers can relate to and support. What method of influence is being used by Apple?

- ☐ fear
- ☐ scarcity
- ☐ authority
- ☒ likeness

Question 10

A threat actor has sent a phishing email to a victim stating that suspicious activity has been detected on their bank account and that they must immediately click on a provided link to change their password. What method of influence is being used by the threat actor?

- ☐ social proof
- ☐ authority
- ☐ likeness
- ☒ urgency

Question 11

Which social engineering physical attack statement is correct?

In the tailgating attack, an unauthorized person tags along with an authorized person to gain entry to a restricted area with the person's consent.

In the piggybacking attack, an unauthorized person tags along with an authorized person to gain entry to a restricted area without the person's consent.

Badge cloning attacks cannot be performed by software.



Shoulder surfing can be prevented by using special screen filters for computer displays.

Question 12

Which tool provides a threat actor a web console to manipulate users who are victims of cross-site scripting (XSS) attacks?

Asterisk

SET



BeEF

Nikto

Question 13

Which Apple iOS and Android tool can be used to spoof a phone number?



SpoofApp

Nessus

Asterisk

BeEF

Question 14

What two physical attacks are mitigated by using access control vestibules? (Choose two.)

- shoulder surfing
- dumpster diving
- ☒ tailgating
- badge cloning
- ☒ piggybacking

Question 15

Which two access control options are commonly used in conjunction with access control vestibules? (Choose two.)

- ☒ proximity card and PIN
- turnstile
- security guard
- toll collector
- ☒ biometric scan

Question 16

Which resource would mitigate piggybacking and tailgating?

- ☒ security guard
- camera
- "no trespassing" warnings
- badge/card access

Question 17

Which tool can launch social engineering attacks and be integrated with third-party tools and frameworks such as Metasploit?

- BeEF
- Nessus
- ☒ SET
- Asterisk

Question 18

Who is the target of a whaling attack?

- ☒ upper managers such as the CEO or key individuals in an organization
- ordinary users
- user groups of social networks such as Facebook and Twitter
- companies that use animals in product testing

Question 19

What is the purpose of a vishing attack?

- to create emails and web pages to collect sensitive information from a user
- ☒ to convince a victim on a phone call to disclose private or financial information
- to use text messages to send malware or malicious links to mobile devices of users
- to use USB sticks to compromise the systems of victims

Question 20

Which Apple iOS and Android tools can spoof a phone number, record calls, and generate different background noises?

- Nessus
- Asterisk
- ☒ SpoofCard
- BeEF

Question 21

A threat actor has sent a text message to a victim stating that they have won bitcoins in a bank contest. To claim their prize, the victim must click the provided link and enter their bank account information. What social engineering attack can be accomplished if the user enters their banking information?

- vishing
- ☒ SMS phishing
- whaling
- watering hole

Question 22

Which tool permits post-exploitation activities, such as Windows reverse VNC DLL and reverse TCP shell?

- BeEF
- ☒ SET
- Nessus
- Nikto

Question 23

Which tool can send fake notifications to the browser of a victim?

- Nexpose
- ☒ BeEF
- Nikto
- Asterisk

Question 24

A new employee is celebrating their position with a large company by posting a picture of their access identification on social media. What kind of physical attack has the new employee unknowingly enabled?

- watering hole
- pivot
- ☒ badge cloning
- shoulder surfing

Question 25

A user has found a USB pen drive in the corporate parking lot. What should the user do with this pen drive?

- throw the pen drive away
- ☒ deliver the pen drive to the security sector of the company
- plug the pen drive into a computer of the company, try to delete all the files, and use the pen drive for personal use
- plug the pen drive into a computer of the company, try to access the files to identify who the pen drive belongs to